

Raport projektu — detekcja w SIEM

Wykrywanie podejrzanych procesów uruchamianych przez interpreter

Środowisko laboratoryjne — Windows 11 + Sysmon + Splunk

ANALITYK	Bartłomiej Kapała
TECHNIKA	MITRE ATT&CK T1204 (User Execution) · T1059 (Command and Scripting Interpreter)
DATA	wrzesień 2026

1. Metryka projektu

Analitik	Bartłomiej Kapała
Cel projektu	Reguła detekcji podejrzanych procesów w SIEM
Platforma SIEM	Splunk Enterprise (licencja Trial)
Źródło danych	Sysmon (Event ID 1 — Process Create)
System monitorowany	Windows 11 (WIN11)
Technika MITRE	T1204 (User Execution), T1059 (Command and Scripting Interpreter)
Severity detekcji	Medium
Klasyfikacja	Projekt laboratoryjny (Detection Engineering)

2. Streszczenie wykonawcze

Celem projektu było zaprojektowanie, wdrożenie i przetestowanie **reguły detekcji w systemie SIEM (Splunk)**, wykrywającej podejrzaną procesy uruchamiane w systemie Windows. Detekcja opiera się na danych z Sysmon (Event ID 1 — tworzenie procesu) i wykrywa procesy uruchamiane z lokalizacji zapisywalnych przez użytkownika (Temp, Downloads, AppData), gdy zostały uruchomione przez interpreter poleceń (PowerShell, cmd).

Reguła została zaimplementowana jako zapytanie SPL, a następnie skonfigurowana jako **alert działający w czasie rzeczywistym**. Skuteczność potwierdzono testem: wygenerowany proces odpowiadający wzorcowi ataku został wykryty, a alert automatycznie się uruchomił.

Kluczowym elementem projektu było **świadome rozwiązanie problemu fałszywych alarmów (false positives)** — zamiast wykluczać legalne aplikacje po nazwie (co tworzyłoby lukę wykorzystywaną przez atakujących), zastosowano korelację z procesem nadrzędnym, wykrywającą wzorzec zachowania, a nie samą nazwę.

3. Cel i zakres

Cel

Zbudowanie działającej reguły detekcji w SIEM, która wykrywa jedną z najczęstszych technik wykonania złośliwego kodu: uruchomienie pliku z lokalizacji zapisywalnej przez użytkownika za pośrednictwem interpretera poleceń.

Zakres

- Konfiguracja źródła danych: podłączenie logów Sysmon do Splunka.
- Opracowanie zapytania detekcyjnego (SPL).
- Obsługa fałszywych alarmów (false positives).
- Konfiguracja alertu czasu rzeczywistego.
- Budowa dashboardu wizualizującego wykrycia.
- Test skuteczności detekcji (kontrolowana symulacja).

4. Architektura rozwiązania

Detekcja opiera się na łańcuchu: generowanie zdarzeń → zbieranie → indeksowanie → wykrywanie → alert.

```
Windows 11 (proces uruchomiony)
|
v
Sysmon → Event ID 1 (Process Create) → Windows Event Log
|
v
Splunk → indeksowanie (index=main)
|
v
Zapytanie SPL → wykrycie wzorca (lokalizacja + proces nadrzędny)
|
v
Alert (real-time) + Dashboard
```

Rola każdego elementu: Sysmon dostarcza szczegółowe dane o procesach (ścieżka, proces nadrzędny, linia poleceń); Splunk indeksuje i przeszukuje te dane; zapytanie SPL definiuje logikę detekcji; alert automatyzuje reakcję.

5. Logika detekcji

5.1 Założenie

Legalne oprogramowanie zwykle działa z katalogów systemowych (Program Files, Windows). Malware i narzędzia atakujących często uruchamiają się z lokalizacji zapisywalnych przez użytkownika (Temp, Downloads, AppData), ponieważ tam trafiają pobrane pliki i nie wymagają podwyższonych uprawnień. Dodatkowym sygnałem jest uruchomienie takiego procesu przez interpreter poleceń (PowerShell, cmd) — typowe dla wykonania payloadu.

5.2 Reguła (zapytanie SPL)

```
index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational"
EventCode=1
(Image="*Temp*" OR Image="*Downloads*" OR Image="*AppData*")
(ParentImage="*powershell*" OR ParentImage="*cmd*")
| table _time, Image, ParentImage, User, CommandLine
```

Wyjaśnienie: pierwszy warunek zawęży do procesów z podejrzanych lokalizacji; drugi — do uruchomionych przez interpreter; komenda table prezentuje istotne pola w czytelnej formie.

6. Obsługa fałszywych alarmów (false positives)

Podczas testów reguła oparta wyłącznie na lokalizacji wykrywała także **legalny proces Microsoft OneDrive** (OneDriveLauncher.exe), który instaluje się w AppData. Był to fałszywy alarm.

Rozważane podejścia

- **Wykluczenie po nazwie** (np. NOT Image="*OneDrive*") — odrzucone. **Tworzy lukę:** atakujący może nazwać malware „OneDrive.exe” i ominąć detekcję (technika masquerading, MITRE T1036).
- **Weryfikacja podpisu cyfrowego** — rozważona, ale konfiguracja Sysmona nie logowała pola podpisu dla tworzenia procesów; niedostępne bez rekonfiguracji.
- **Korelacja z procesem nadrzędnym** — wybrane rozwiązanie.

Zastosowane rozwiązanie

Legalny OneDrive jest uruchamiany przez systemowy proces **svchost.exe**, natomiast podejrzane procesy — przez **interpreter (PowerShell/cmd)**. Dodanie warunku na proces nadrzędny (ParentImage) odfiltrowało OneDrive bez wykluczania po nazwie. Reguła wykrywa **wzorzec zachowania**, a nie nazwę — jest więc odporna na podszywanie się.

Zaleta: korelacja pozwala zachować szeroki zakres lokalizacji (włącznie z AppData) bez fałszywych alarmów — filtruje po kontekście uruchomienia, nie zawężając monitorowanego obszaru.

7. Konfiguracja alertu

Typ alertu	Real-time (czas rzeczywisty)
Warunek wywołania	Per-Result (dla każdego wykrytego zdarzenia)

Akcja	Add to Triggered Alerts (priorytet: Medium)
Opis / mapowanie	MITRE T1204 / T1059 — potencjalne wykonanie payloadu

Uzasadnienie severity (Medium): wykrycie stanowi sygnał wczesnego ostrzegania (potencjalne wykonanie), wymagający triażu przez analityka — nie jest to potwierdzony incydent. Może eskalować do wyższego priorytetu po analizie kontekstu (np. gdy proces wykazuje dalszą złośliwą aktywność). Poziom Critical zarezerwowano dla potwierdzonych, poważnych incydentów.

8. Test skuteczności

Detekcję zweryfikowano w kontrolowanej symulacji:

1. **Wygenerowanie testu:** skopiowanie legalnego pliku wykonywalnego do katalogu Temp i uruchomienie go z poziomu PowerShell (odwzorowanie wzorca: proces z lokalizacji zapisywalnej uruchomiony przez interpreter).
2. **Wykrycie:** reguła SPL zwróciła wygenerowany proces (Image w Temp, ParentImage powershell), pomijając legalne procesy.
3. **Alert:** alert czasu rzeczywistego uruchomił się automatycznie i został dodany do listy Triggered Alerts.

Wynik: detekcja zadziałała zgodnie z założeniem — wykryła symulowane zagrożenie i wygenerowała alert.

9. Panel (dashboard)

Zbudowano panel wizualizujący wykrycia, złożony z trzech elementów:

- **Wykryte procesy z podejrzanych lokalizacji** — tabela zdarzeń (czas, ścieżka, proces nadrzędny, użytkownik, linia poleceń).
- **Wykryte procesy łącznie** — licznik (single value) pokazujący sumę wykryć.
- **Wykres w czasie** — rozkład wykryć na osi czasu (timechart), ukazujący kiedy wystąpiły zdarzenia.

Dashboard stanowi „widok analityka” — pozwala jednym spojrzeniem ocenić liczbę i rozkład wykryć w czasie.

10. Wnioski i wyciągnięte lekcje

- **Detekcja oparta na zachowaniu > detekcja oparta na nazwie:** korelacja proces + proces nadrzędny jest odporna na podszywanie się (masquerading), w przeciwieństwie do wykluczeń po nazwie.
- **False positives to nieodłączny element detekcji:** legalne aplikacje (OneDrive) mogą pasować do reguły; ich obsługa bez tworzenia luk to kluczowa umiejętność detection engineer.
- **Detekcja ogranicza się do logowanych pól:** brak podpisu cyfrowego w danych Sysmon wymusił zmianę podejścia — regułę można oprzeć tylko na faktycznie zbieranych danych.
- **Severity detekcji ≠ severity incydentu:** wykrycie to sygnał wczesnego ostrzegania wymagający triażu, nie automatycznie potwierdzony atak.
- **Kompromis zakres/precyzja:** korelacja z kontekstem pozwala zachować szeroki zakres monitorowania bez nadmiaru fałszywych alarmów.

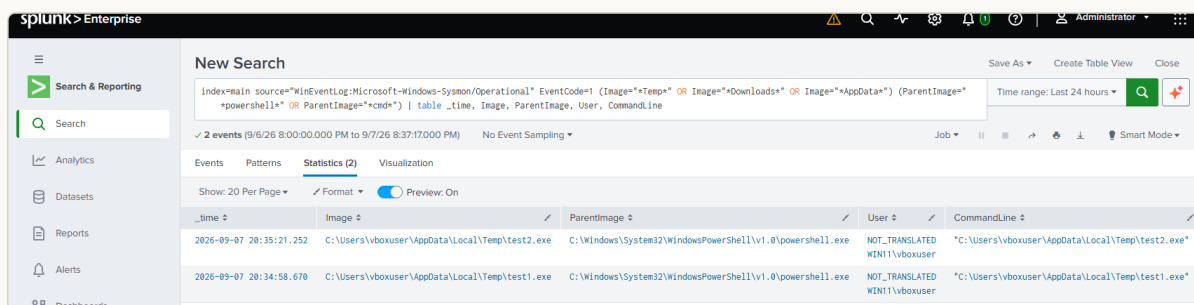
11. Możliwe rozwinięcia

- Włączenie logowania podpisu cyfrowego w Sysmon i dodanie warunku na nieważny/brakujący podpis (druga warstwa detekcji).

- Rozszerzenie o kolejne interpretery i techniki (wscript, mshta, rundll32) oraz analizę linii poleceń (encoded commands).
- Przełożenie reguły na format Sigma (przenośność między systemami SIEM).
- Wzbogacenie o threat intelligence (sprawdzanie hashy w VirusTotal).
- Automatyczna reakcja (SOAR) — np. izolacja hosta po wykryciu.

12. Załączniki / Dowody

Do raportu dołączono następujące zrzuty ekranu z systemu Splunk (środowisko WIN11):



New Search

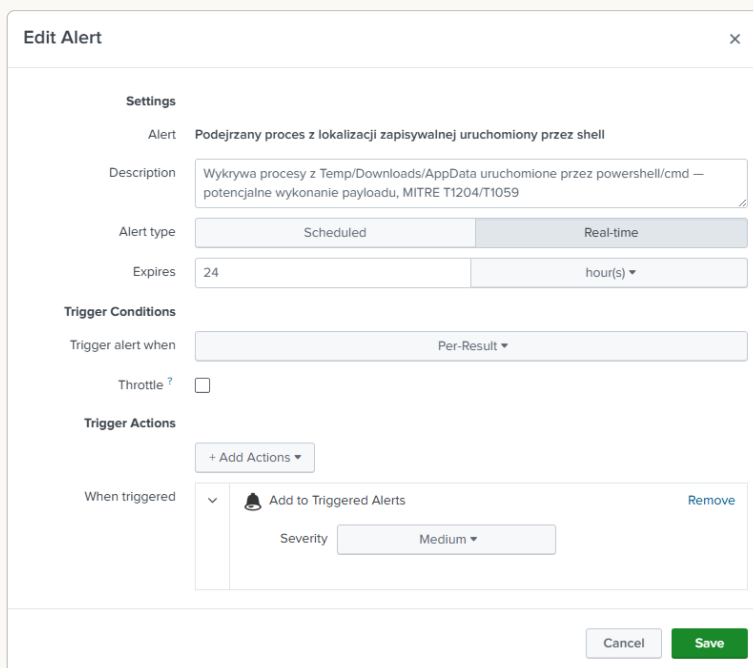
index=main source="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 (Image="*Temp*" OR Image="*Downloads*" OR Image="*AppData*") (ParentImage="*powershell*" OR ParentImage="*cmd*") | table _time, Image, ParentImage, User, CommandLine

Time range: Last 24 hours

2 events (9/6/26 8:00:00.000 PM to 9/7/26 8:37:17.000 PM) No Event Sampling

_time	Image	ParentImage	User	CommandLine
2026-09-07 20:35:21.252	C:\Users\vboxuser\AppData\Local\Temp\test2.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	NOT_TRANSLATED WIN11\vboxuser	"C:\Users\vboxuser\AppData\Local\Temp\test2.exe"
2026-09-07 20:34:58.670	C:\Users\vboxuser\AppData\Local\Temp\test1.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	NOT_TRANSLATED WIN11\vboxuser	"C:\Users\vboxuser\AppData\Local\Temp\test1.exe"

Zař. 1. Reguła detekcji (SPL) wraz z wynikiem — tabela wykrytych procesów.



Edit Alert

Settings

Alert: Podejrzaný proces z lokalizacji zapisywalnej uruchomiony przez shell

Description: Wykrywa procesy z Temp/Downloads/AppData uruchomione przez powershell/cmd — potencjalne wykonanie payloadu, MITRE T1204/T1059

Alert type: ☐ Scheduled ☒ Real-time

Expires: 24 hour(s)

Trigger Conditions

Trigger alert when:

Throttle: ☐

Trigger Actions

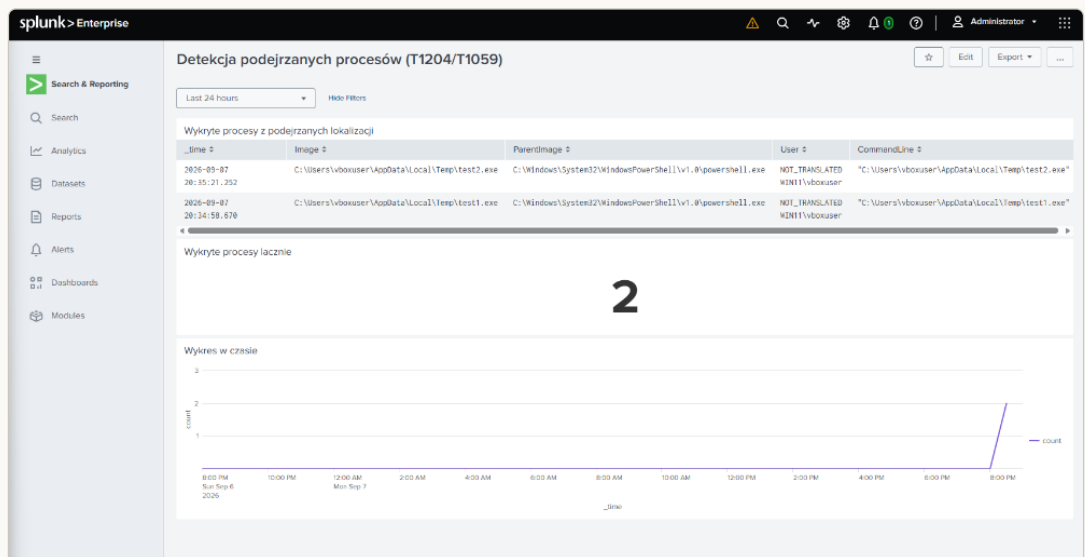
+ Add Actions

When triggered: ☒ Add to Triggered Alerts Remove

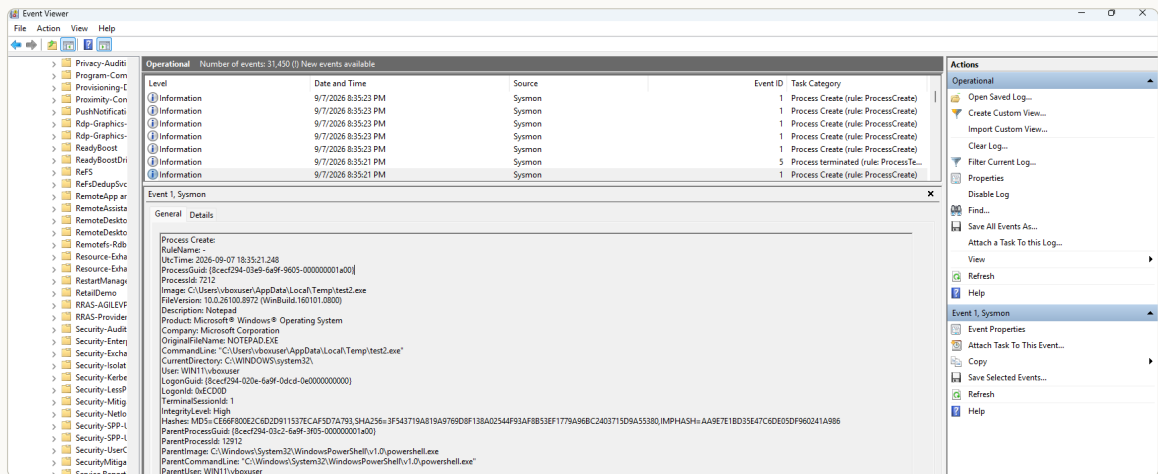
Severity:

Cancel Save

Zař. 2. Konfiguracja alertu — typ real-time, warunek per-result, mapowanie MITRE w opisie.



Załącznik 3. Dashboard — trzy panele (tabela wykrytych procesów, licznik łączny, wykres w czasie).



Załącznik 4. Zdarzenie źródłowe Sysmon (Event ID 1) — proces uruchomiony z Temp, proces nadrzędny PowerShell.

Projekt zrealizowany w kontrolowanym środowisku laboratoryjnym. Reguła detekcji oparta na danych Sysmon indeksowanych w Splunk.